Segurança de Dados

MCTA023-17

Criptografia Assimétrica:
Autenticidade, Integridade, Irretratabilidade e Assinatura;
Infraestrutura de Chave Pública

Profª Denise Goya

Roteiro

Criptografia de Chave Pública (Criptografia Assimétrica):

- Assinatura Digital
  - Integridade
  - Autenticidade
  - Irretratabilidade
- Infraestrutura de Chave Pública

Assinatura Digital

Curiosidade Relevante: RSA é Comutativo

O RSA funciona, isto é, a decifragem recupera corretamente a mensagem cifrada, pois:

$$[\,(m^{e})\bmod n\,]^{d} \bmod n = m$$

Também é possível demonstrar que:

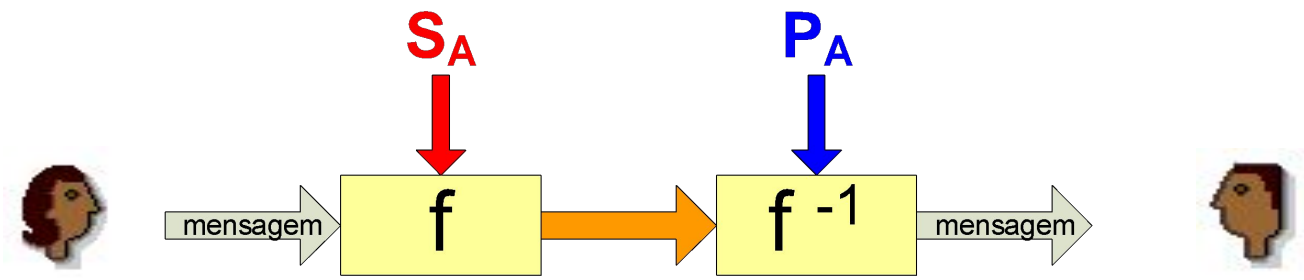
$$[\,(m^{d})\bmod n\,]^{e} \bmod n = m$$

Ou seja, o RSA é comutativo: é possível operar usando a chave secreta e, depois, inverter a operação usando a chave pública

Autenticidade de Origem

Alice envia uma mensagem **operada** com sua **chave secreta S_A** para Beto

Beto inverte a operação aplicando a **chave pública P_A** de Alice; quando a inversão é bem sucedida tem-se autenticidade da origem (Alice)



Como o RSA é comutativo, é possível usá-lo para garantir Autenticidade de origem. Nesse caso, tem-se um esquema de **Assinatura Digital**

Assinatura Digital

Recurso criptográfico que garante a **autenticidade de origem** da mensagem;

Analogamente a uma assinatura em papel, a assinatura digital nos dá uma indicação de que o documento foi **confirmado** por quem o assinou

Assinatura Digital

Caso do RSA:

- Aplica-se o algoritmo usando a chave secreta (isso é dito "assinar")
- A operação inversa é feita com a chave pública (dito "verificar a assinatura")

Resultado:

- Se a inversão for bem sucedida para uma determinada chave pública, significa que somente quem possui a chave secreta pode ter assinado o documento.

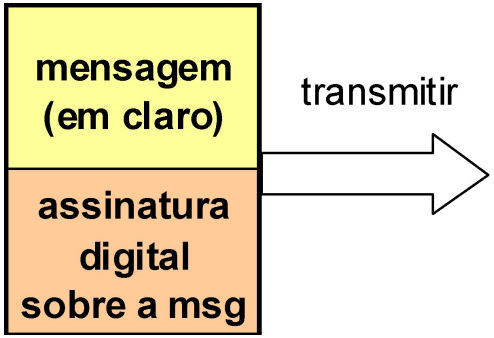
Autenticidade sem Sigilo

Muitas vezes, no envio de uma mensagem, é necessária a garantia de **autenticidade** da mensagem, mas não o sigilo dela.

Ex.: atualizações de segurança de um sistema operacional: código requer autenticidade do fabricante, mas deve ser público

Uma solução:

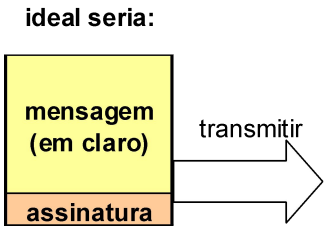
- transmitir a mensagem (não cifrada)
- transmitir a assinatura digital, junto com a mensagem



Comprimento da Assinatura

Caso do RSA:

- O texto cifrado com RSA (original) terá mesmo tamanho que a mensagem
- Isto é, a assinatura é tão longa quanto a mensagem



Como diminuir o tamanho da assinatura?

- Solução: usar funções que “resumem a cifra”: Hash

Assinatura Digital com Hash (sem sigilo):

- Em vez de assinar a mensagem inteira, faz-se:
  - gera-se o Hash da mensagem
  - assina-se apenas o Hash desta mensagem, usando a chave secreta
  - envia a mensagem e a assinatura digital em anexo (hash)
- O receptor recebe a mensagem e a assinatura:
  - calcula o hash da mensagem recebida
  - verifica a assinatura usando a chave pública, comparando com o hash calculado
  - se forem iguais, a assinatura é válida e está autenticada a origem da mensagem recebida (caso contrário, rejeita)

Assinatura Digital: Propriedades

Com a assinatura digital, garante-se:

a **autenticidade de origem** da mensagem, uma vez que só será possível verificar a assinatura usando-se a chave pública do emissor.

e também a **integridade** da mensagem, pois se houver alguma alteração (adulteração) do texto ou da assinatura, não será possível realizar o processo de verificação com sucesso.

Algoritmos de Assinatura Digital

DSS (Digital Signature Standard)

- padronização do NIST-EUA, 1994
- DSA - Digital Signature Algorithm; ECDSA (DSA sobre curvas elípticas)

Outros algoritmos

- Assinatura de ElGamal (DSA é variante desta)
- Assinatura de Schnorr; vários outros. . .

Algoritmos de assinatura digital pós-quânticos (tema de seminário):

- Baseados em reticulados: CRYSTALS-Dilithium; FALCON
- Baseado em Hash: SPHINCS+

DSA

DSA: Algoritmos

O DSA (Digital Signature Algorithm) é composto por três algoritmos:

- de geração de chaves
- para assinar
- para verificar a assinatura

Assinatura DSA - Geração de Chaves

São parâmetros públicos do sistema:

- um primo p, relativamente longo
- um primo q que divide $(p-1)$
- g gerador de Z_p^* tal que $g^q = 1 \bmod p$

Cada usuário do sistema, digamos Alice, precisa ter um par de chaves:

- A chave secreta de Alice é S, com $0 \leq S < (q-1)$, escolhida ao acaso
- Alice calcula e divulga como sendo sua chave pública $T = g^S \bmod p$

Assinatura DSA - Algoritmo para Assinar

Dado um texto, x, com $0 < x < p$,

Alice escolhe aleatoriamente um valor k, com $1 \leq k \leq q-1$

Calcula $C = (g^k \bmod p) \bmod q$

Calcula $D = (x + SC)(k^{-1}) \bmod q$

A assinatura de Alice para x é (C, D)

Alice envia para Beto o texto x assinado: (x,C,D)

Assinatura DSA - para Verificar

Beto recebe *(x,C,D)* e confere se a assinatura é válida:

Se *C* e *D* não forem positivos menores que *q*, a assinatura é rejeitada;

Calcula:

$$e_1 = xD^{-1} \bmod q$$

$$e_2 = CD^{-1} \bmod q$$

Se $(g^{e1} \cdot T^{e2} \bmod p) \bmod q = C$,

então a assinatura é correta; caso contrário, considerada inválida

DSA: Por que Funciona?

Dadas as condições de geração de chave e cálculos efetuados, o algoritmo verifica corretamente a assinatura se e só se o par de chaves (secreta, pública) for usado para assinar/verificar (esboço da demonstração):

$$(g^{e1} \,.\, T^{e2} \bmod p) \bmod q =$$

$$= (g^{x.D^{-1} \bmod q} . (g^{s})^{C.D^{-1} \bmod q} \bmod p) \bmod q =$$

$$= (g^{(x+SC).D^{-1} \bmod q} \bmod p) \bmod q =$$

$$= (g^{k} \bmod p) \bmod q =$$

$$= C$$

DSA: Segurança

Problema computacional associado:

- Logaritmo discreto:

conhecidos p, g e $T=(g^S \bmod p)$,

é inviável calcular **S** em tempo razoável, para valores arbitrários de p

Também é inviável, em tempo computacional eficiente, falsificar uma assinatura sem o conhecimento de **S**

Padronização: FIPS PUB 186-4: Digital Signature Standard (DSS), 2013, csrc.nist.gov

Trabalho em Equipes

- Entrega-1:
  - Feedback no Moodle para o grupo ao longo da semana
- Entrega-2:
  - texto final com máximo
  - prazo: 24/março (grupos
    ou 07/abril: demais
- Apresentações:
  - Haverá uma atividade pa
  - Conteúdo para a Prova F

Apresentações (20 a 30 minutos por grupo)
2 a 3 grupos por data
aloque seu grupo em uma data após combinar com todos integrantes
todas as apresentações acontecem na sala de aula (Teoria)

Datas	Grupos (use a numeração G1 a G20)		
24/mar.			
31/mar.			
2/abr.			
7/abr.			
9/abr.			
14/abr.			
16/abr.			

Escolham a data de apresentação

+ ≡ temas cronograma

Aplicação de Assinatura Digital
e
Irretratabilidade

Exemplo de Uso

Internet Banking:

Dados do pagamento:

Código de barras:	39994 08580 33121 02
Valor do documento:	R$ 0,00
Valor de juros/multa:	R$ 0,00
Valor de desconto/abatimento:	R$ 0,00
Valor do pagamento:	R$ 0,00
Data do vencimento:	10/01/2013

Pagamento efetuado em 10/01/2013

Autenticação:

0E31E8D917B7FA4C1758226F1AF22E1D8D47CB7B

assinatura digital
de 160 bits
efetuada pelo banco,
sobre o documento
de pagamento

Irretratabilidade

A assinatura convencional em papel possui a seguinte característica:

- quem assina um documento não pode negar que o assinou (juridicamente, assinatura em documentos e reconhecimento de firma por Autoridade com fé pública)

a isso chamamos **irretratabilidade**

Irretratabilidade e Assinatura Digital

Algoritmos de assinatura digital **podem** oferecer característica de irretratabilidade

- depende de como são geradas as chaves pública e privada;
- se a chave secreta de um usuário é de **exclusivo** conhecimento dele, a assinatura tem característica de irretratabilidade;
- quando mais de um usuário conhece uma chave secreta, ninguém garante qual dos usuários realmente assinou um documento.

Custódia de Chaves

Existem sistemas que são estruturados de tal forma que alguém, além do usuário, conhece a chave secreta

- a isso se chama **custódia de chaves**
- pode ser útil em alguns casos, como:
  - desligamento/morte de um funcionário ou diretor não tornaria documentos sigilosos inacessíveis
  - segurança nacional

- Custódia de chave impede a característica de irretratabilidade

Autenticação de Chave Pública

Questão Fundamental

Em criptografia de **chave pública**, a assinatura digital pode garantir

- autenticidade
- integridade
- irretratabilidade (em alguns casos)

O que acontece se alguém mal intencionado divulgar uma **falsa chave pública** de um usuário qualquer?

- Quebra total dos serviços acima
- Não só para assinatura digital, mas para qualquer esquema de chave pública

Como Autenticar a Chave Pública?

Como garantir que a chave pública de alguém é dela mesma?

Solução comum: usar certificados emitidos por uma autoridade certificadora.

Um certificado digital atesta a veracidade de uma chave pública.

Certificado Digital de Chave Pública

É um documento que garante que uma chave pública é legítima (de um determinado usuário)

- impede que usuários verifiquem assinaturas válidas para remetente falso

  ex: numa transação bancária, é fundamental que se tenha a certeza de que no outro lado da linha há o banco verdadeiro.

- Muitos sites oferecem certificado digital, para assegurar o usuário de que o site é verdadeiro (principalmente para *e-commerce* e *internet banking*).

Certificado Digital de Chave Pública

Padronização X-509

Quem deseja publicar a sua chave pública, entra em contado com uma entidade confiável, que é conhecida como Autoridade Certificadora (AC)

A AC atesta a autenticidade de uma chave pública, assinando-a com a sua própria chave privada (segredo da AC)

A AC gera um certificado digital

Ex: Certificado

Visualizador do certificado: moodle.ufabc.edu.br

Geral Detalhes

Emitido para

Nome comum (CN)	moodle.ufabc.edu.br
O (Organização)	FUNDACAO UNIVERSIDADE FEDERAL DO ABC - UFABC
Unidade organizacional (OU)	<Não faz parte do certificado>

Emitido por

Nome comum (CN)	RNP ICPEdu OV SSL CA 2019
O (Organização)	Rede Nacional de Ensino e Pesquisa - RNP
Unidade organizacional (OU)	<Não faz parte do certificado>

Ex: Certificado

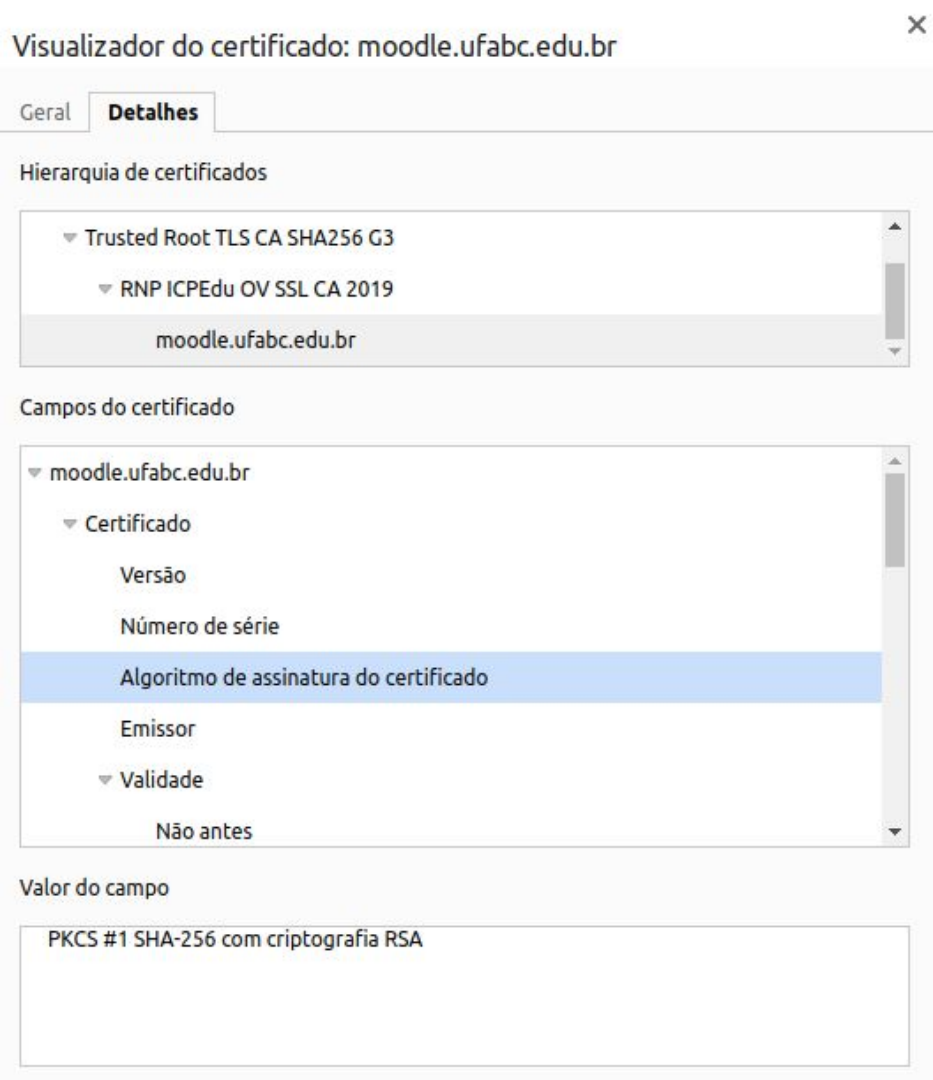
Período de validade

Emitido em	terça-feira, 21 de junho de 2022 às 12:11:06
Expira em	domingo, 23 de julho de 2023 às 12:11:05

Assinaturas digitais

Assinatura digital SHA-256	1C 36 4E ED D4 EE CA 0C 79 E2 11 EB D2 94 7C C8 02 61 C3 2B 27 62 8D 2D 6F 8E FB 29 B6 27 03 D5
Assinatura digital SHA-1	DE AC B9 7A 4A 55 DA 36 70 7C 62 15 AE B4 36 7D 7D 4E C9 4B

Ex: Certificado



Visualizador do certificado: moodle.ufabc.edu.br

Geral | **Detalhes**

Hierarquia de certificados

- Trusted Root TLS CA SHA256 G3
  - RNP ICPEdu OV SSL CA 2019
    - moodle.ufabc.edu.br

Campos do certificado

- Informações da chave pública do requerente
  - Algoritmo da chave pública do requerente
  - Chave pública do requerente
- Extensões
  - Uso da chave de certificado
  - Acesso às informações de autoridade
  - Diretivas de certificação
  - Restrições básicas do certificado

Valor do campo

```
Módulo (4096 bits):
 BA 61 5C A6 C9 08 86 40 6A 86 35 71 1C ED 4D A8
B4 A6 D7 89 B0 FB A5 14 8B 4A 55 62 7C F9 2D 54
A9 0A 6F F6 05 29 99 25 EC FF 91 07 9B 8D A1 8D
26 11 F5 8D 19 07 DA 07 F1 8F B5 70 22 6C 60 AF
8A 14 E3 D3 2C 82 7A 10 6D 76 4D 19 D2 C3 F1 33
```

Chave pública do requerente

Valor do campo

```
30 43 28 77 AE E8 25 91 B1 A3 F2 AF FB D3 D1 FD
73 2A EC FF 59 CD 1D 0E 4E F0 EA 34 B2 77 14 E5
00 F5 8F 2D FE 17 D9 39 6B E5 12 56 69 37 01 95

Expoente público (17 bits):
01 00 01
```

Infraestrutura de Chaves Públicas: ICP

Autoridade certificadora (AC)

- emite, distribui e revoga certificados

Autoridade de registro (AR)

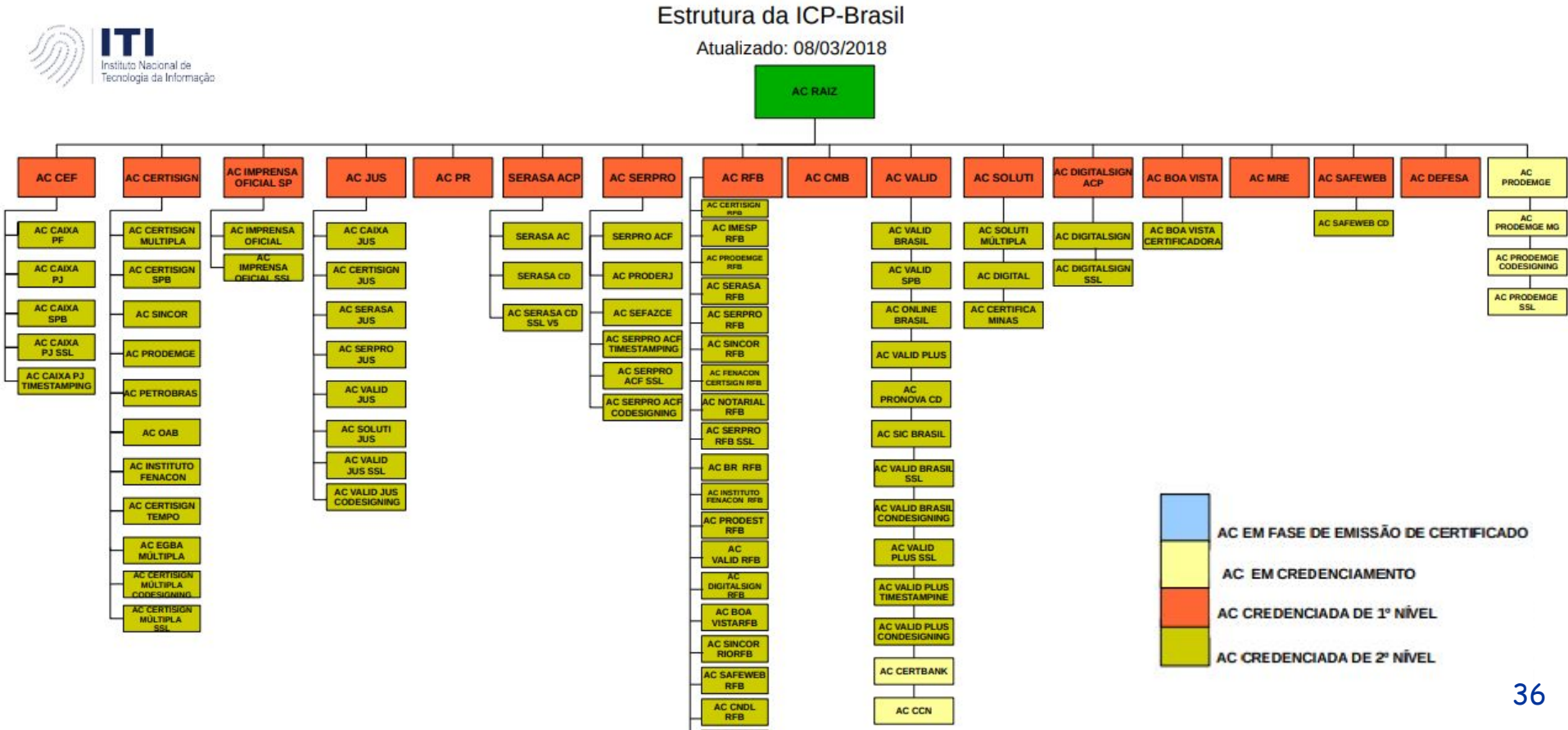
- auxilia a AC para cadastrar usuários e garantir a legitimidade destes

Hierarquia de autoridades certificadoras:

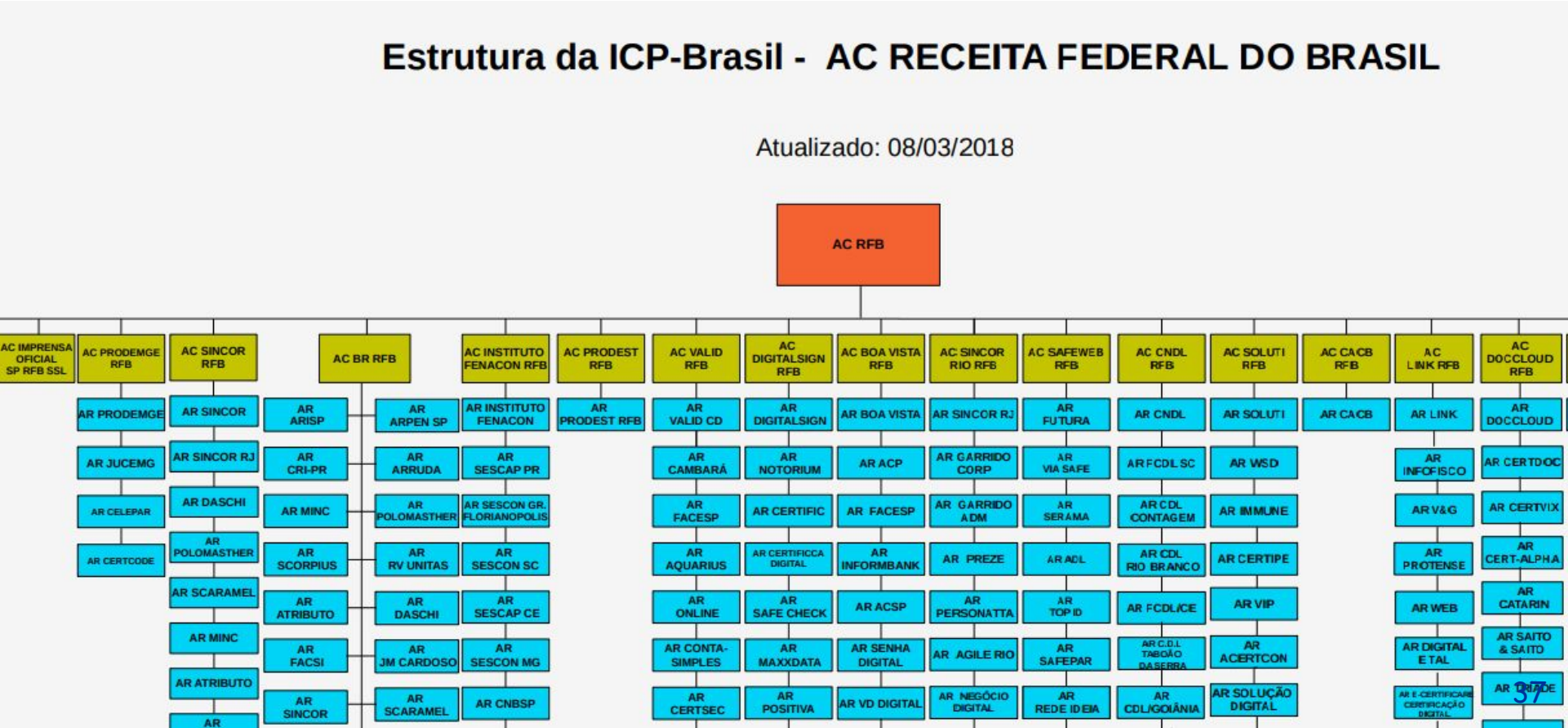
- AC-Raiz e várias outras ACs abaixo desta

No Brasil: ICP-Brasil

ICP-Brasil


ITI
Instituto Nacional de Tecnologia da Informação
Estrutura da ICP-Brasil
Atualizado: 08/03/2018
AC RAIZ
AC CEF
AC CAIXA PF
AC CAIXA PJ
AC CAIXA SPB
AC CAIXA PJ SSL
AC CAIXA PJ TIMESTAMPING
AC CERTISIGN
AC CERTISIGN MULTIPLA
AC CERTISIGN SPB
AC SINCOR
AC PRODEMGE
AC PETROBRAS
AC OAB
AC INSTITUTO FENACON
AC CERTISIGN TEMPO
AC EGBA MÚLTIPLA
AC CERTISIGN MÚLTIPLA CODESIGNING
AC CERTISIGN MÚLTIPLA SSL
AC IMPRENSA OFICIAL SP
AC IMPRENSA OFICIAL
AC IMPRENSA OFICIAL SSL
AC JUS
AC CAIXA JUS
AC CERTISIGN JUS
AC SERASA JUS
AC SERPRO JUS
AC VALID JUS
AC SOLUTI JUS
AC VALID JUS SSL
AC VALID JUS CODESIGNING
AC PR
SERASA ACP
SERASA AC
SERASA CD
AC SERASA CD SSL V5
AC SERPRO
SERPRO ACF
AC PRODERJ
AC SEFAZCE
AC SERPRO ACF TIMESTAMPING
AC SERPRO ACF SSL
AC SERPRO ACF CODESIGNING
AC RFB
AC CERTISIGN RFB
AC IMESP RFB
AC PRODEMGE RFB
AC SERASA RFB
AC SERPRO RFB
AC SINCOR RFB
AC FENACON CERTSIGN RFB
AC NOTARIAL RFB
AC SERPRO RFB SSL
AC BR RFB
AC INSTITUTO FENACON RFB
AC PRODEST RFB
AC VALID RFB
AC DIGITALSIGN RFB
AC BOA VISTARFB
AC SINCOR RIORFB
AC SAFEWEB RFB
AC CNDL RFB
AC CMB
AC VALID
AC VALID BRASIL
AC VALID SPB
AC ONLINE BRASIL
AC VALID PLUS
AC PRONOVA CD
AC SIC BRASIL
AC VALID BRASIL SSL
AC VALID BRASIL CONDESIGNING
AC VALID PLUS SSL
AC VALID PLUS TIMESTAMPINE
AC VALID PLUS CONDESIGNING
AC CERTBANK
AC CCN
AC SOLUTI
AC SOLUTI MÚLTIPLA
AC DIGITAL
AC CERTIFICA MINAS
AC DIGITALSIGN ACP
AC DIGITALSIGN
AC DIGITALSIGN SSL
AC BOA VISTA
AC BOA VISTA CERTIFICADORA
AC MRE
AC SAFEWEB
AC SAFEWEB CD
AC DEFESA
AC PRODEMGE
AC PRODEMGE MG
AC PRODEMGE CODESIGNING
AC PRODEMGE SSL
AC EM FASE DE EMISSÃO DE CERTIFICADO
AC EM CREDENCIAMENTO
AC CREDENCIADA DE 1º NÍVEL
AC CREDENCIADA DE 2º NÍVEL

ICP-Brasil: Exemplo de AC de 1º Nível



ICP-Brasil: Exemplo de AC de 1º Nível

Serviços da Receita Federal:

e-CPF e *e-CNPJ*

Várias AC de 2º nível, abaixo das quais, várias AR, como bancos

Próxima Aula

- Autenticação e Controle de Acesso

Trabalho em Equipes

- Entrega-1:
  - Feedback no Moodle para o grupo ao longo da semana
- Entrega-2:
  - texto final com máximo
  - prazo: 24/março (grupos
    ou 07/abril: demais
- Apresentações:
  - Haverá uma atividade pa
  - Conteúdo para a Prova F

Apresentações (20 a 30 minutos por grupo)
2 a 3 grupos por data
aloque seu grupo em uma data após combinar com todos integrantes
todas as apresentações acontecem na sala de aula (Teoria)

Datas	Grupos (use a numeração G1 a G20)		
24/mar.			
31/mar.			
2/abr.			
7/abr.			
9/abr.			
14/abr.			
16/abr.			

Escolham a data de apresentação

+ ≡ temas cronograma

Estudo Individual

Leituras Sugeridas

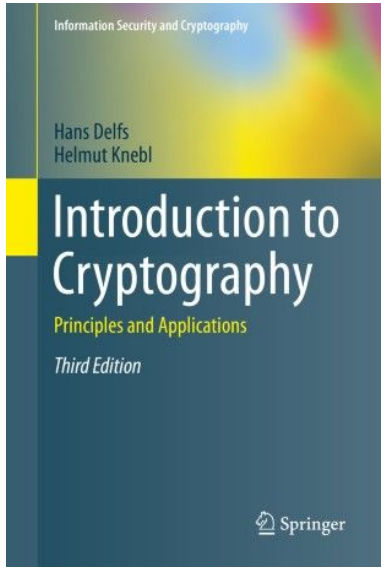
- Jerônimo C. Pellegrini, Introdução a Criptografia e seus Fundamentos - Notas de aula - versão preliminar, Capítulo 9. (2019), disponível em http://aleph0.info/cursos/ic/notas/

- Faleiros, A.C., Criptografia, capítulo 3, série Notas em Matemática Aplicada. SBMAC, 2011, disponível em http://www.sbmac.org.br/arquivos/notas/livro_52.pdf

Outras Leituras

Tutorial para acesso a Livros via Cafe Capes, com login institucional UFABC:

https://portal.biblioteca.ufabc.edu.br/images/docs/Orientacoes_para_o_acesso_remoto_via_CAFe.pdf



Logado, acesse:

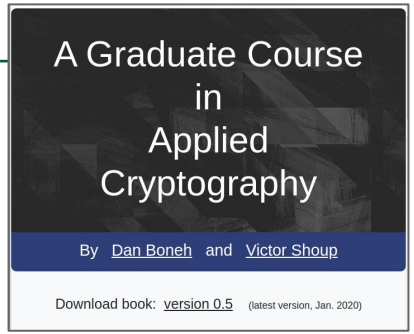
https://link-springer-com.ez42.periodicos.capes.gov.br/book/10.1007/978-3-662-47974-2

e leia Capítulo 3 de

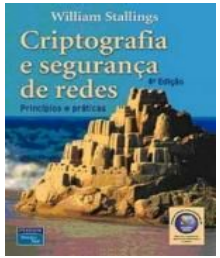
Hans Delfs, Helmut Knebl. Introduction to Cryptography Principles and Applications, Springer (2015)

Outras Leituras

- Dan Boneh e Victor Shoup, A Graduate Course in Applied Cryptography, Capítulo 13, 2020. Disponível em https://toc.cryptobook.us/



- Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall, 2008.



- Terada, R. Segurança de Dados, 2.ed. Editora Blucher, 2008.

Questões de Autoavaliação

(não precisa entregar)

Exercício

Explique o que significa dizer que um certificado digital possui uma assinatura RSA. Que garantias de segurança isso traz?